SPIKA TECH™

PROTECCIÓN DEL CORREO ELECTRÓNICO Y LA NAVEGACIÓN WEB

HISTORIAL DEL DOCUMENTO			
Versión	**Resumen de modificaciones**	**Fecha de entrada**	**Sustituye a (Código, revisión)**
01	Primera versión del documento.	12/03/2025	N/A

REGISTRO DE FIRMAS			
Función:	**Elaborado por:**	**Revisado por:**	**Aprobado por:**
Departamento:	Responsable del SGSI	Dirección	Jefe de seguridad (o suplente)
Nombre:	David Pozo	Carlos Rodrigo	Carlos Zúñiga
Firma:	Firmado por POZO SANCHEZ DAVID - ***6992** el día 12/03/2025	Firmado por RODRIGO RIVERO, CARLOS (AUTENTICACIÓN) el día 13/03/2025	Firmado por ***8264** CARLOS ZUÑIGA (R: ****8690*) el día 13/03/2025 con un
Fecha:	12/03/2025	12/03/2025	12/03/2025

CONTENIDO

1 OBJETIVO 4
2 ALCANCE 4
3 NORMATIVA APLICABLE 4
4 PROTECCIÓN DEL CORREO ELECTRÓNICO 4
4.1 Protección de la información y archivos adjuntos 4
4.2 Detección de suplantación 5
4.3 Protección frente a código dañino 5
4.4 Seguridad del servidor de correo 5
4.5 Limitaciones al uso personal del correo electrónico 5
5 PROTECCIÓN DE LA NAVEGACIÓN WEB 5
5.1 Redes sociales 5
5.2 Buenas prácticas en la gestión de un perfil corporativo 7
5.3 Configuración de cuentas en X 8
5.4 Configuración de cuentas en LinkedIn 11
5.5 Configuración de cuentas en Instagram 15
5.6 Filtrado de webs 18
6 REFERENCIAS 18

1 OBJETIVO

El presente documento pretende establecer el marco y acciones a realizar para prevenir, detectar y responder a amenazas basadas en correo electrónico y en la navegación web. Mediante el presente procedimiento se establecerán los mecanismos y herramientas a seguir en aras de proteger tanto la información y archivos adjuntos del correo electrónico, como el propio medio de comunicación en sí.

2 ALCANCE

Este procedimiento se aplica en todos los sistemas de información que dan soporte a los servicios de SPIKA TECH.

Asimismo, esta norma de uso debe ser conocida por todos los usuarios que conforman SPIKA TECH.

3 NORMATIVA APLICABLE

Es aplicable toda la normativa establecida en el documento de **RGS_1N NORMATIVA APLICABLE.**, que se actualizara de forma periódica Las Políticas, Normas y Procedimientos dentro del alcance.

4 PROTECCIÓN DEL CORREO ELECTRÓNICO

4.1 Protección de la información y archivos adjuntos

Con el objetivo de proteger la información y los archivos adjuntos, desde SPIKA TECH se contará con herramientas que permitan un análisis y filtrado de los correos electrónicos. Para ello, se realizará un filtrado del correo electrónico, análisis de direcciones, comprobación del remitente del correo electrónico, filtro anti-spam, etc.

Además, se monitorizará el sistema de correo corporativo para detectar envíos de correos electrónicos de gran tamaño.

4.2 Detección de suplantación

Se utilizarán herramientas que permitan detectar la suplantación de identidad por correo y BEC con verificación de remitentes y detección de dominios.

4.3 Protección frente a código dañino

Todos los recursos de transmisión de información, incluidos los servidores de correo contarán con herramientas de protección frente a código dañino propia de los correos electrónicos, con el objetivo de proteger y detectar aquellos correos que pudiesen contener archivos maliciosos adjuntos.

Para evitar la contaminación del receptor de un correo electrónico se utilizarán sistemas antivirus, tanto en el equipo donde se lee el mensaje como en servidores de correo intermedios, si aplica.

Para ello, la herramienta iniciará un procedimiento de cuarentena para el correo electrónico. Este procedimiento se explicará en un apartado posterior.

4.4 Seguridad del servidor de correo

Además de todo ello, se utilizarán protocolos de comunicación que proporcionen seguridad entre el usuario y el servidor de correo electrónico si aplicase.

4.5 Limitaciones al uso personal del correo electrónico

Los derechos y deberes de los usuarios con respecto al uso personal del correo electrónico se encuentran recogidos en la Normativa del Uso de los recursos y Sistemas de Información de SPIKA TECH.

5 PROTECCIÓN DE LA NAVEGACIÓN WEB

5.1 Redes sociales

Con independencia de la red social que uses, debes tener en cuenta las siguientes consideraciones:

a) Ten cuidado con lo que publicas en redes sociales de forma abierta. Por ejemplo, si publicas una foto en la que se puede ver la calle donde vives, un atacante puede obtener los datos de tu identidad y domicilio. Si luego públicas que estás de vacaciones fuera de tu domicilio, es posible que acaben robando en tu casa, o que te llegue una multa falsa haciéndose pasar por la DGT mediante una carta.

b) Usa siempre doble factor de autenticación y contraseñas fuertes para proteger tus redes sociales.

c) No uses el correo corporativo para darte de alta en redes sociales.

d) Tienes que ser consciente de la información personal que compartes en tu perfil, por si en algún momento recibes un correo de phishing que explota dicha información. Procura ser consciente de tu grado de exposición.

e) Verifica siempre las personas que quieren ser tus contactos en redes sociales.

f) No abras enlaces o archivos que te compartan por redes sociales a través de personas que no conozcas, por muy interesante que te parezca.

g) No proporciones información tuya, de tu empresa o compañeros con personas que no conozcas, por ejemplo, si te piden tu correo profesional para mandarte algo, el correo de alguien de la empresa o que identifiques la persona responsable de algún área de la empresa. El chat de LinkedIn permite enviar documentos y enlaces, por lo que no es necesario dar tu correo personal o profesional a nadie que no conoces.

h) No des por cierto el perfil profesional de nadie, si no has tenido un contacto directo con esa persona y, además, dicho contacto ha sido dentro de su ambiente de trabajo.

i) Ten cuidado con los anexos y enlaces que te envían o aparecen en redes sociales. Las técnicas que usan son similares a las de los correos de Phishing, por lo que mantente siempre en guardia.

j) No todo lo que te llega de alguien conocido puede que sea algo bueno. En ocasiones, los delincuentes toman el control de una cuenta de un usuario e intentan infectar al resto de usuarios de la red. Si recibes algo raro, ponte en contacto con la persona que te lo ha mandado y pregúntale si te lo ha mandado voluntariamente.

5.2 Buenas prácticas en la gestión de un perfil corporativo

A continuación, se ofrecen una serie de pautas a tener en cuenta por centros u organismos públicos que deseen crear un perfil corporativo en las redes sociales:

1. **No facilitar información de carácter personal en las publicaciones.** Cuando se proceda a publicar, o a facilitar información que será accesible públicamente, no se debe incluir datos de carácter personal, ni confidencial, que engloben a personal sanitario, pacientes, familiares, otros trabajadores, etc. Por ejemplo, se puede redactar un "*post*" informativo, que enlace a la página donde puede encontrar más información, o publicar información que sea interesante para la audiencia.
2. **No responder a consultas sobre información de carácter personal a los ciudadanos a través de las RRSS**. En caso de manejar un perfil corporativo en una red social, será habitual que las personas contacten mediante mensajes privados, incluso a través de mensajes públicos para todas las personas, sobre información médica, o solicitando información de carácter confidencial. En estos casos, se les debe indicar que esa información la pueden consultar a través de los cauces adecuados, facilitándoles un enlace a la plataforma correspondiente. Asimismo, se debe incluir una referencia a que sus datos no serán tratados ni almacenados, para lo cual, se puede utilizar la siguiente cláusula: "*De conformidad con la Ley Orgánica 3/2018 de 5 de diciembre, no se guardarán los datos personales que Vd. nos envía en el correo electrónico al que se contesta con este mail, puesto que en el mismo no inicia procedimiento alguno al ser de carácter puramente informativo*".

3. **Precaución respecto a las contraseñas empleadas.** En el caso de contar con perfil corporativo en diversas redes sociales es importante no utilizar la misma contraseña en todas ellas. El uso de una contraseña maestra siempre es desaconsejado, ya que si alguien consiguiera hackear una de ella podría entrar en todas las demás redes. Asimismo, la contraseña empleada debe ser robusta, y se deberá modificar periódicamente. De esta manera, podremos evitar posibles ataques a nuestra cuenta.

4. **Hacer uso de las redes sociales desde un dispositivo que no contenga información confidencial.** Es importante que, si se pretende hacer uso corporativo de las redes sociales, las mismas se utilicen desde un dispositivo que no almacene otro tipo de información confidencial, puesto que, por ejemplo, en los supuestos en los

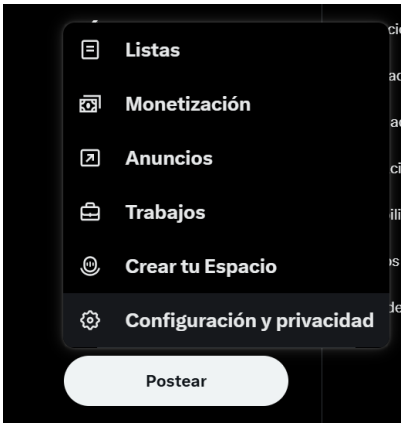
que se realizase un ataque a través de esta red social mediante el envío de archivos o URLs maliciosas, podría comprometer el equipo y por consiguiente la información que se almacene en el mismo.

5. **No abrir ni acceder a enlaces facilitados o documentos facilitados por usuarios en una red social.** Las RRSS son uno de los medios más utilizados por los ciberdelincuentes para realizar ataques de *phishing.* Por tanto, para evitar caer en la trampa es importante no

5.3 Configuración de cuentas en X

Para configurar tu cuenta de X, de una manera segura, se deberán realizar las siguientes acciones:

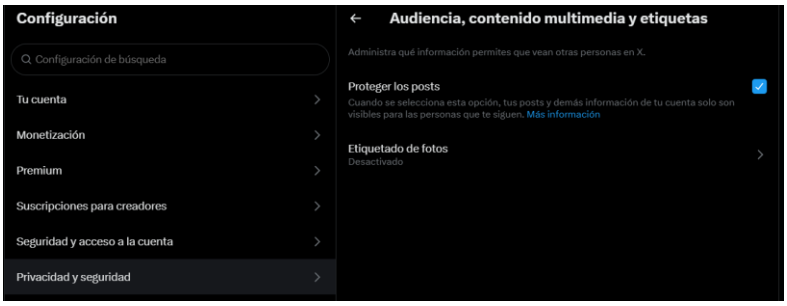
En el panel lateral izquierdo, encima de la acción “Postear”, encontrareis el campo “Más opciones”, y tras pinchar aparecerá un desplegable, y entre las diferentes opciones se debe acceder a **“Configuración y privacidad”.**

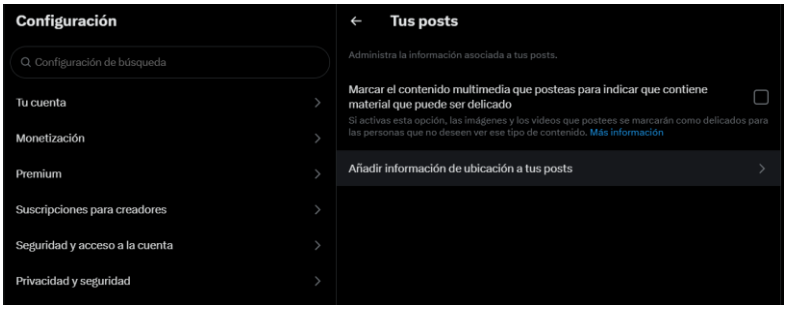


Una vez dentro de “Configuración y privacidad”, en primer lugar, vamos a acceder a **“Privacidad y seguridad”**. Aquí se debe realizar los siguientes ajustes en los apartados de **“Tus posts”**:

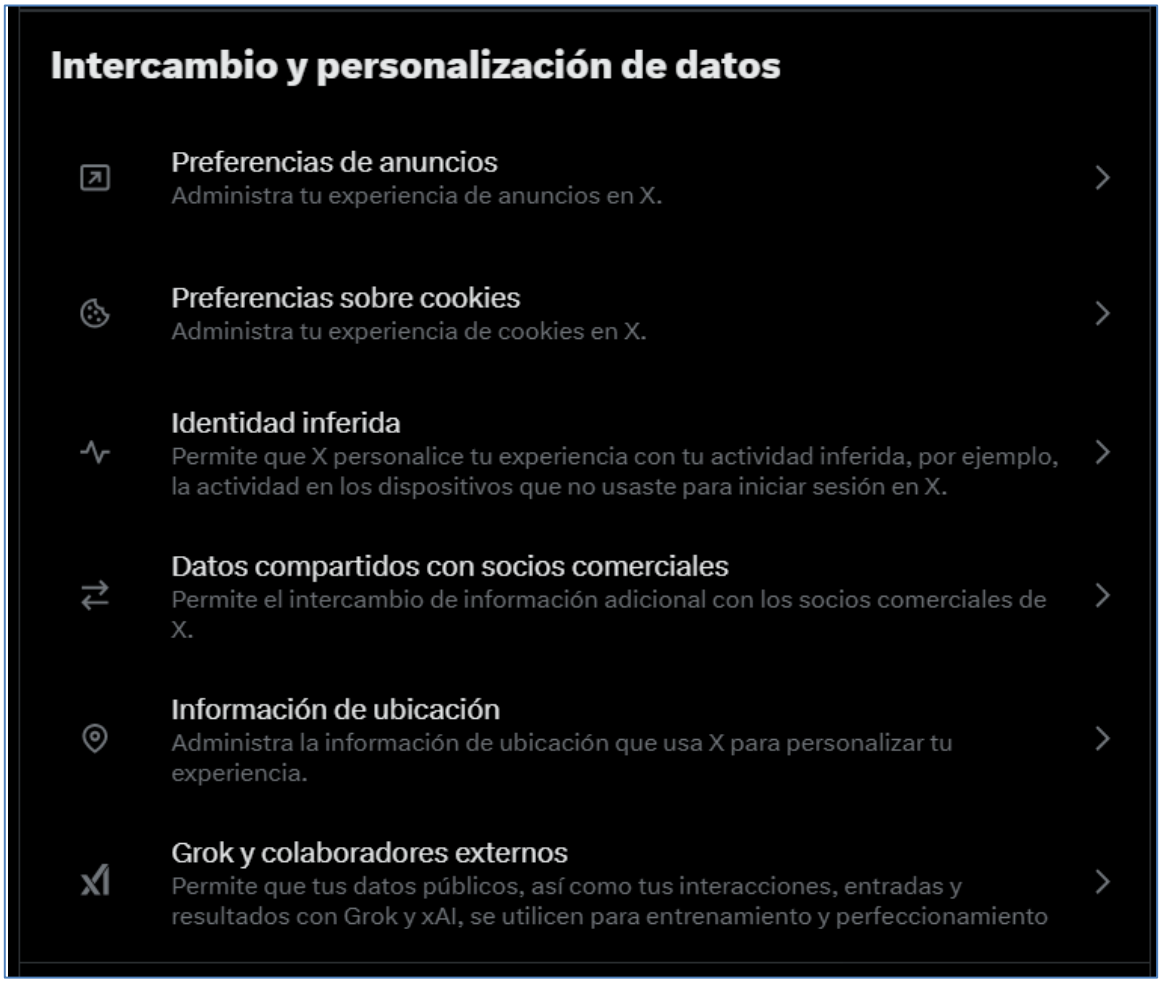
1. **Protege tus posts.** Debemos activar esta opción si no queremos que lo que publicamos sea de dominio público, es decir, podemos conseguir que la información solo sea visible para nuestros seguidores. Para el caso de los perfiles públicos no es necesario activar esta opción.

2. **Información de ubicación.** En esta pestaña debemos acceder para comprobar que no aparezca la ubicación de cada tweet que publiquemos, ya que de lo contrario estaríamos permitiendo que la gente que visualice nuestras publicaciones pueda saber dónde nos encontramos en cada preciso momento.
3. **Etiquetado de fotos.** La opción debe encontrarse desactivada, ya que de lo contrario podrían etiquetarnos en cualquier publicación sin nuestro consentimiento.

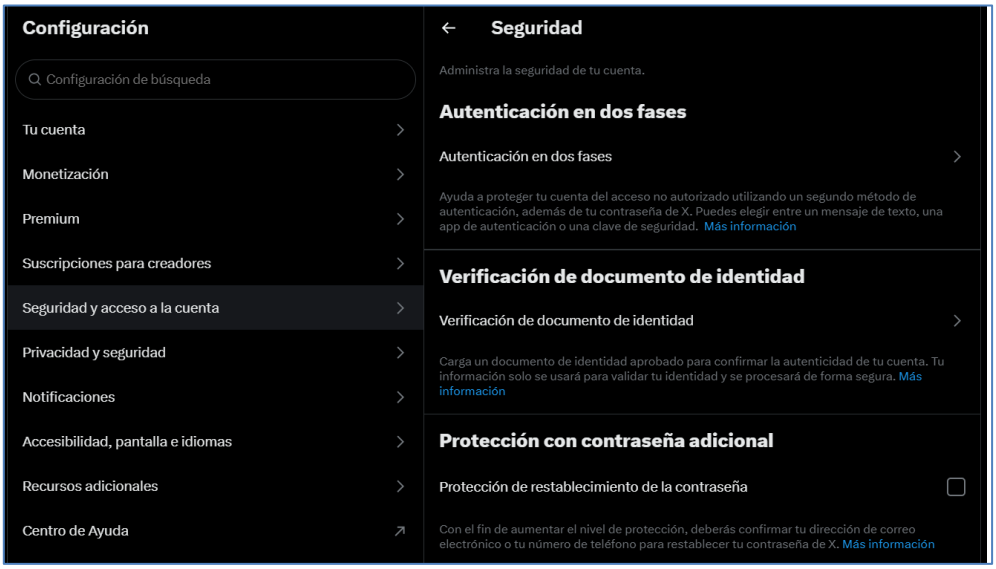




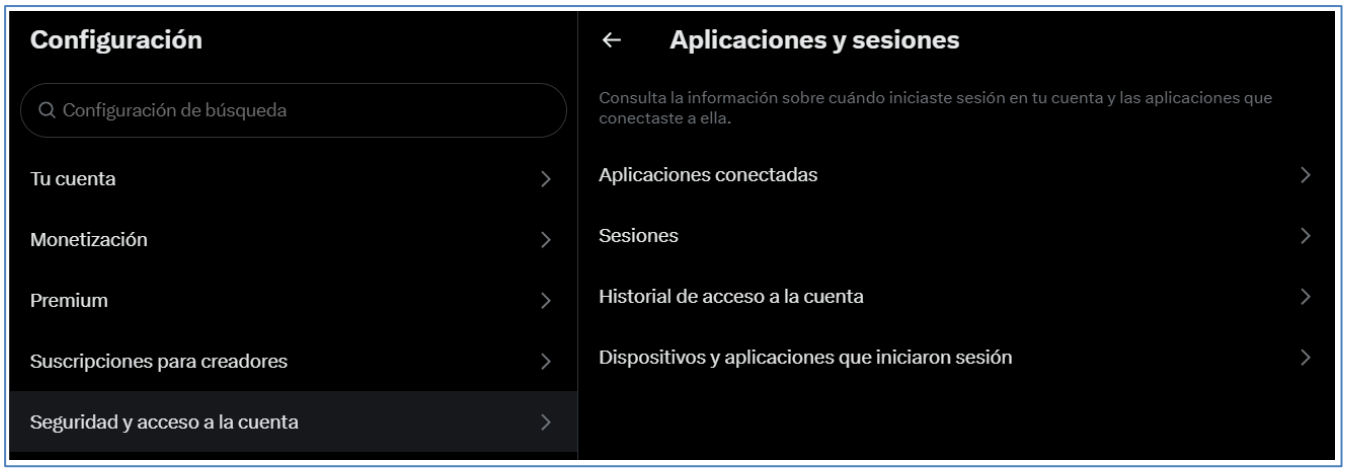
Tras realizar estas modificaciones debemos acceder dentro de “Privacidad y Seguridad” a **“Personalización y datos”**, en esta ocasión se debe desactivar las opciones de personalización del contenido, para evitar, en la medida de lo posible, que la plataforma ceda nuestros datos a terceros, o haga perfilados de la información que facilitamos en su red social.



Posteriormente, accederemos a la pestaña de "**Seguridad y acceso a la cuenta**", que podéis encontrar dentro de **"Configuración y privacidad"**, y activaremos la autentificación en dos pasos (la plataforma ofrece distintas modalidades de activación). Asimismo, nos permite la opción de proteger la cuenta con una contraseña adicional, que sería recomendable activar, ya que en caso de que alguien accediera a nuestro email, necesitaría introducir esta segunda contraseña para poder acceder a nuestro perfil en la red social de Twitter.



Por último, dentro del apartado "**Seguridad y acceso a la cuenta**", accederemos a "**Aplicaciones y sesiones**", y dentro de esta sección, al igual que con Facebook, podremos cerrar todas las sesiones que se encuentren actualmente activas. Es una manera de cerciorarnos que nadie más puede entrar en nuestros terminales sin nuestra autorización.



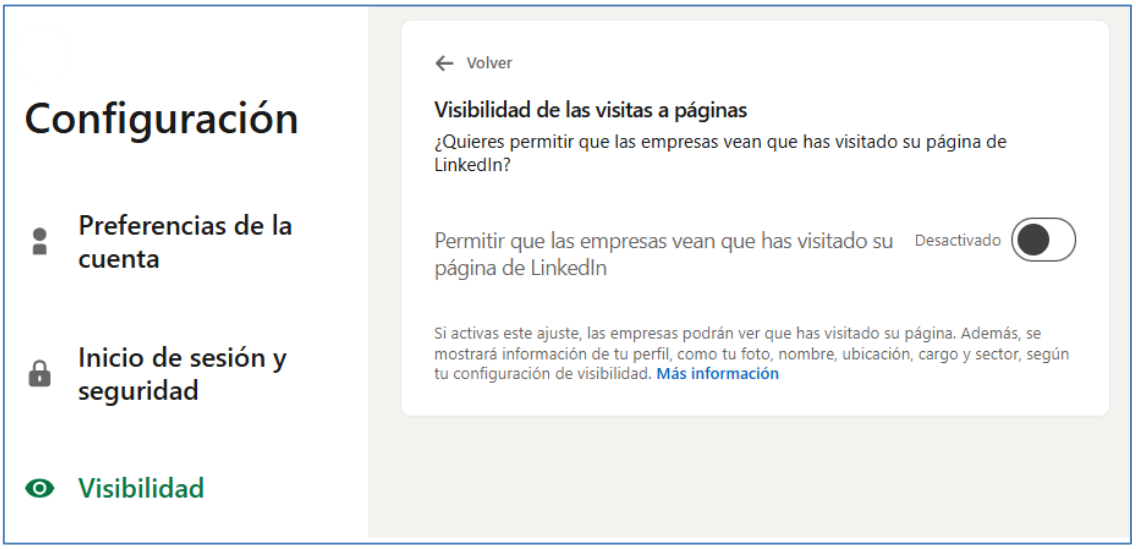
5.4 Configuración de cuentas en LinkedIn

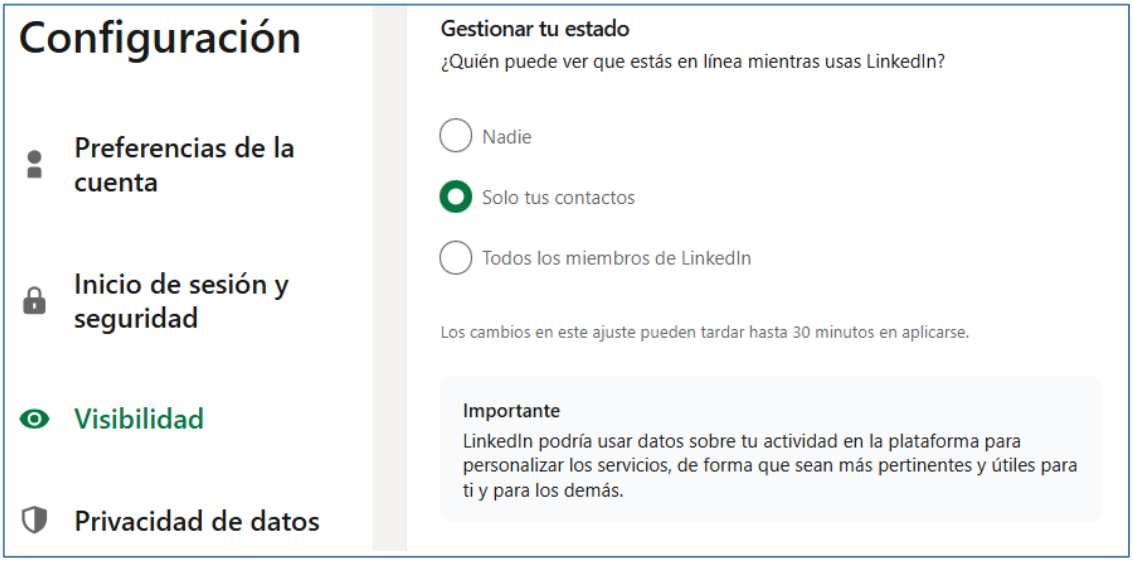
En esta red social, entendemos que, en cierta manera, se puede ser más laxo a la hora de configurar la privacidad de los contenidos, ya que es utilizada por la gran mayoría para exponer su trayectoria a profesionales a terceras personas o empresas.

No obstante, será necesario realizar algunos ajustes, por lo que, tras acceder a nuestra sesión de usuario debemos **acceder a "Yo"** y **desplegar el panel de opciones** que aparece para acceder posteriormente **a "Ajustes y privacidad".**

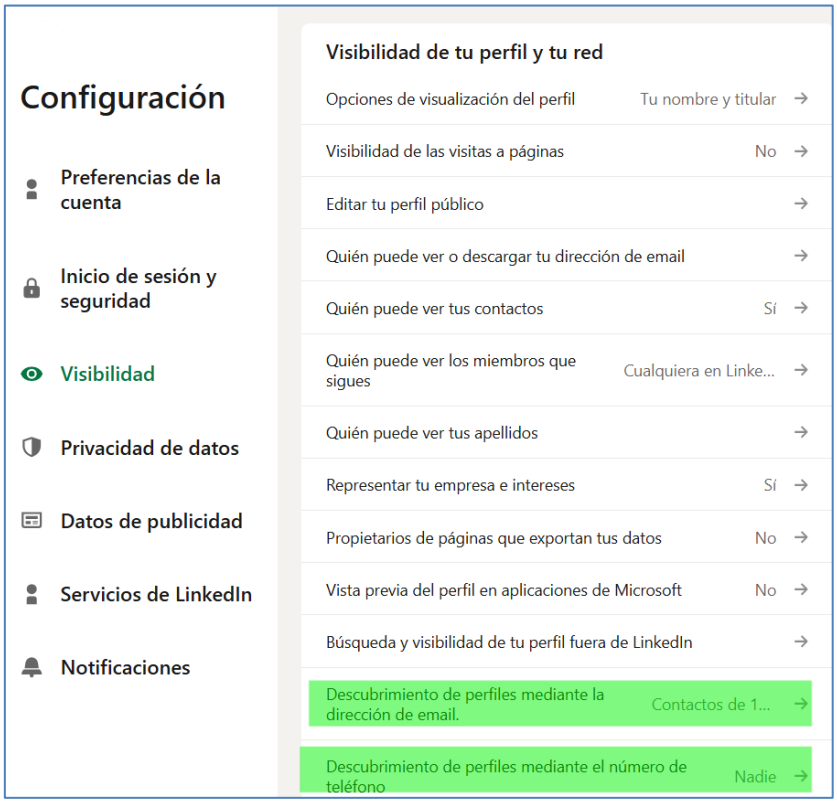
Una vez dentro de Configuración y privacidad accederemos a **"Visibilidad > Quién puede ver o descargar tu dirección de email"**, y debemos establecer que la dirección de email sea **"solo visible para mí"**. Asimismo, hemos de verificar que la dirección de contacto no sea descargable por parte de otros usuarios de la red social.

Tras realizar estas acciones vamos a seleccionar que no sea visible nuestro perfil fuera de LinkedIn, opción disponible dentro de **"Visibilidad de las visitas a páginas".** Dentro de esta sección, modificaremos también la opción **"Visibilidad > Visibilidad de tu actividad en LinkedIn > Gestionar tu Estado",** opción que permite a terceros ver si estás en **"línea"** dentro de la aplicación. En esta opción, lo más seguro sería que nadie viera nuestro estado, no obstante, lo recomendado, al menos, es que solo sea visible por nuestros contactos.

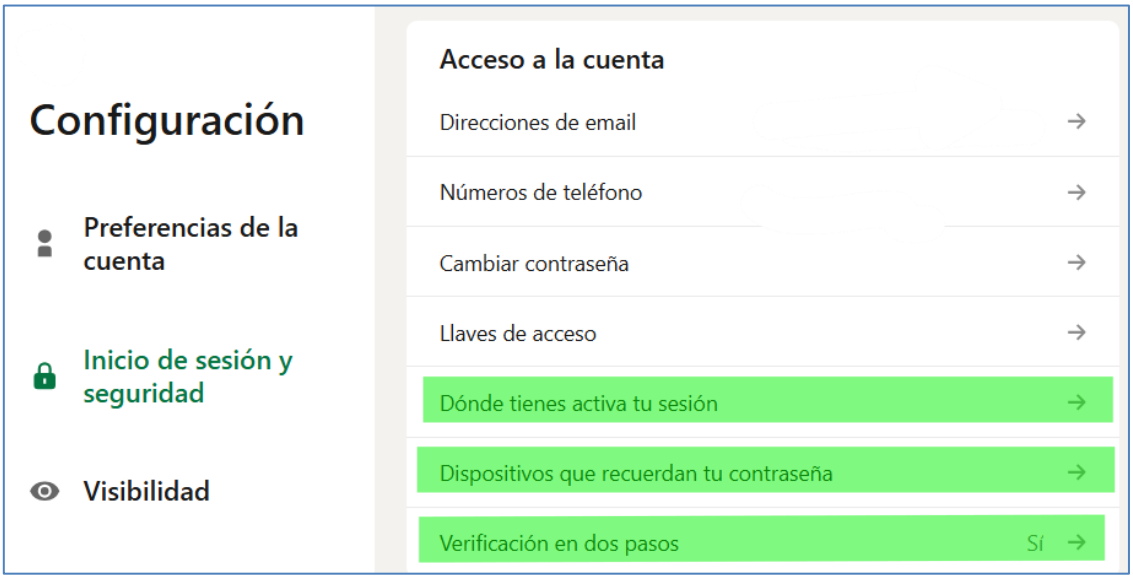




Posteriormente, en la sección “Visibilidad > **Visibilidad de tu perfil y tu red > Descubrimiento de perfiles mediante la dirección de email y Descubrimiento de perfiles mediante el número de teléfono**”, debemos configurar quién nos puede encontrar mediante email o número de teléfono, para establecer que “**Nadie**” nos pueda encontrar mediante estos datos personal, ya que, de lo contrario, cualquier persona que haya accedido a esos datos personales podrá saber nuestra identidad en la plataforma.



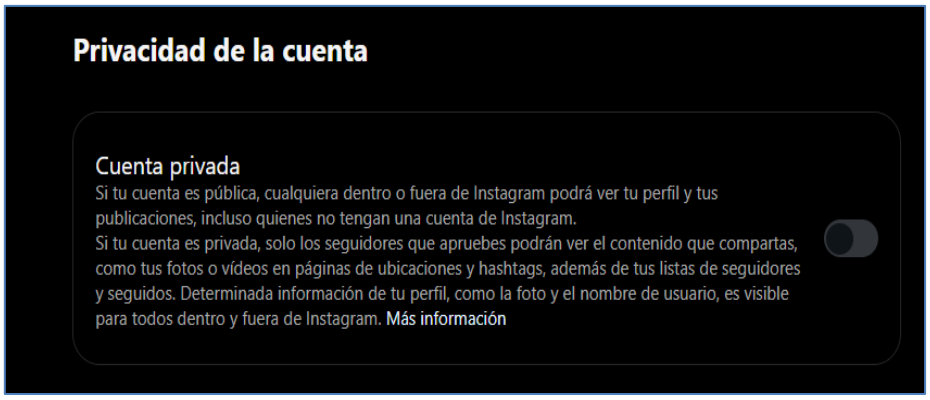
Una vez configurada la privacidad, vamos a proceder a **modificar la seguridad en la plataforma**, para lo cual, accederemos a "**Inicio de sesión y seguridad**", y posteriormente a **"Dónde tienes activa tu sesión"**. En esta sección podremos cerrar las sesiones que tengamos abiertas con anterioridad ("Dónde has iniciado sesión"), debemos cerciorarnos de que no haya dispositivos que recuerden nuestra contraseña, y podremos activar la "verificación en dos pasos".



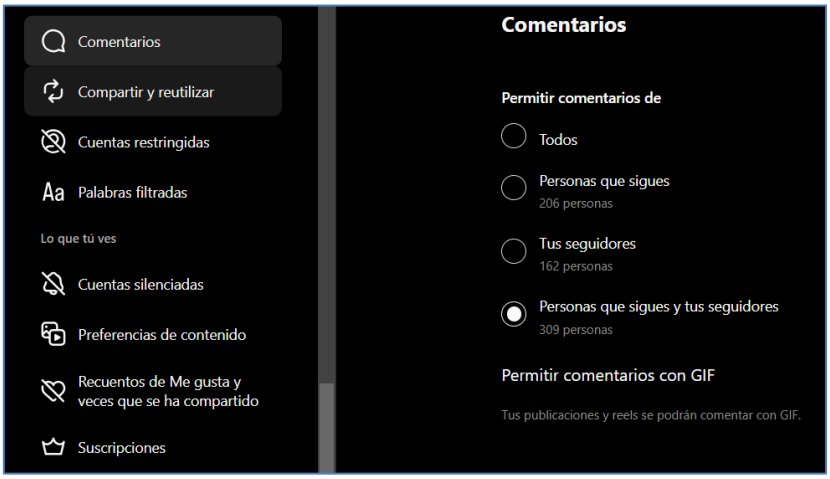
5.5 Configuración de cuentas en Instagram

Para una correcta configuración de nuestra privacidad y seguridad en esta plataforma, lo primero que debemos hacer es situarnos en nuestro perfil, y una vez dentro debemos pinchar en las **tres rallas paralelas** en la parte superior derecha de la aplicación, y una vez clickado aparecerá un desplegable, donde podréis encontrar la sección de **“Configuración”. Una vez dentro, accederemos a “Privacidad de la cuenta”**.

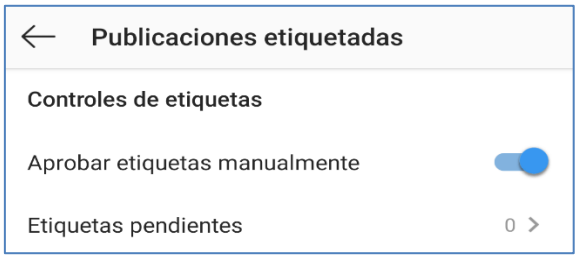
Una vez dentro de "**Privacidad de la cuenta**", para perfiles de uso privado estableceremos que la "**Privacidad de la cuenta**" sea privada, mientras que para un perfil corporativo no habría inconveniente en que apareciera como público.



Seguidamente, en el apartado "**Comentarios**" es recomendable que no aparezca activada la opción de "**Todos**" en la sección "**Permitir comentarios de**" ya que, de lo contrario, cualquier usuario de la aplicación podrá contactar con nosotros.



Para acabar en la sección de “Privacidad”, en la sección de “**etiquetas y menciones**”, al igual que en Facebook, debemos proceder a activar la opción de “**Aprobar etiquetas manualmente**”.



Tras configurar la privacidad, vamos a modificar los parámetros de “**Centro de cuentas**” de la aplicación, que aparece en la sección “**Configuración**”:

1. **Actividad de inicio de sesión**. Podremos cerrar aquellas sesiones que se encuentren activas en otros dispositivos, entrando en “**Contraseña y seguridad > Donde has iniciado sesión”**.

2. **Información de inicio de sesión guardada**. Es recomendable que no aparezca guardada esta información en ningún dispositivo, ya que de lo contrario cualquiera podría acceder a través de ese terminal.

3. **Autenticación en dos pasos**. En esta sección podremos configurar esta opción que, como hemos visto, dota de mayor seguridad ante posibles accesos de terceros no consentidos.

5.6 Filtrado de webs

Como parte del control de acceso y la gestión de riesgos relacionados con el uso de recursos tecnológicos, se implementará un sistema de filtrado de sitios web que restringe el acceso a contenidos no autorizados o que representen un riesgo para la seguridad de la información. Las categorías de sitios restringidos incluyen, entre otros, aquellos relacionados con actividades ilícitas, redes sociales no autorizadas, servicios de entretenimiento no permitidos y descargas de software no verificadas. Las políticas de filtrado se revisan y actualizan periódicamente para garantizar su alineación con las necesidades organizacionales y los cambios en el panorama de amenazas.

6 REFERENCIAS

- ISO/ IEC 27001:2022
    - 5.14 Transferencia de la información.
    - 8.12 Prevención de fugas de datos.
    - 5.10 Uso aceptable de la información y activos asociados.
    - 5.23 Seguridad de la información para el uso de servicios en la nube.

- 6.2 Términos y condiciones de contratación.
- 6.3 Concienciación, educación y formación en seguridad de la información.
- 8.23 Filtrado Web.